

# Chapter 17 Review

## **Chapter Summary**

After reading this chapter and completing the exercises, you should understand the following about web components, e-mail, and IM security.

### **Describe the functioning of the TLS protocol suite**

- TLS uses a combination of symmetric and asymmetric cryptographic methods to secure traffic.
- Before a TLS session can be secured, a handshake occurs to exchange cryptographic information and keys.

### **Explain web applications, plug-ins, and associated security issues**

- Web browsers have mechanisms to enable plug-in programs to manage applications such as Flash objects and videos.
- Plug-ins that block pop-up windows and phishing sites can improve end-user security by permitting greater control over browser functionality.

### **Describe secure file transfer options**

- FTP operations occur in plaintext, allowing anyone who sees the traffic to read it.
- SFTP combines the file transfer application with the Secure Shell (SSH) application to provide for a means of confidential FTP operations.

### **Explain directory usage for data retrieval**

- LDAP is a protocol describing interaction with directory services.
- Directory services are data structures optimized for retrieval and are commonly used where data is read many times more than written, such as ACLs.

### **Explain scripting and other Internet functions that present security concerns**

- Scripts are pieces of code that can execute within the browser environment.
- Some scripts or code elements can be called from the server side.

### **Use cookies to maintain parameters between web pages**

- Cookies are small text files used to maintain state between web pages.
- Cookies can be set to persistent (last for a defined time period) or session (expire when the session is closed).

### **Examine web-based application security issues**

- As more applications move to a browser environment to ease programmatic deployment, it makes it easier for users to work with a familiar user environment.
- Browsers have become powerful programming environments that perform many actions behind the scenes for a user, and malicious programmers can exploit this hidden functionality to perform actions on a user's PC without the user's obvious consent.

### **Describe security issues associated with e-mail**

- Malicious code is code that performs something harmful to the computer it runs on. Malicious code is often sent through e-mail.
- Viruses are pieces of malicious code that require user action to spread.
- Worms are pieces of malicious code that use automated methods to spread.
- Spam, or unsolicited commercial e-mail, is e-mail that is sent to you without you requesting it, attempting to sell you something. It is the electronic equivalent of a telemarketing call.
- Hoax e-mails are e-mails that travel from user to user because of the compelling story contained in them.

### **Implement security practices for e-mail**

- Protecting your e-mail system from virus code requires several measures:
  - Don't execute any attachment from an unknown source.
  - Use antivirus programs that run on the server to filter all e-mails.
  - Use client-side antivirus programs to catch any viruses that might come from web-based e-mail accounts.
- Keeping all software up to date helps to prevent worm propagation.
- Server-side filtering software and the application of Spam Blackhole Lists help limit the amount of unsolicited e-mail.
- E-mail encryption is a great way to protect the privacy of communication since e-mail is a cleartext medium.
- PGP, or Pretty Good Privacy, is a good specific application for e-mail encryption.
- S/MIME, or Secure/Multipurpose Internet Mail Extension, is the e-mail protocol that allows encryption applications to work.
- Antivirus software is important to protect against malware.

### **Detail the security issues of instant messaging protocols**

- The most popular IM programs all send messages in the clear, without native encryption built into the default clients.
- All the IM clients need to attach to a server to communicate. Therefore, when attached to the server, they announce the source IP of a particular user.
- Instant messaging can also be used to transfer files. This activity typically bypasses any security built into the network, especially mail server virus protections.

### **Key Terms**

Active Server Pages (ASP) (663)  
ASP.NET (663)  
Authenticode (666)  
botnet (675)  
browser extension (665)  
browser helper objects (BHOs) (666)  
code signing (667)  
cookie (663)  
DomainKeys Identified Mail (DKIM) (684)

e-mail (670)  
e-mail hoax (674)  
File Transfer Protocol (FTP) (658)  
Hypertext Markup Language (HTML) (650)  
inlining (667)  
instant messaging (IM) (689)  
Internet Engineering Task Force (IETF) (652)  
Java (661)  
JavaScript (661)  
Lightweight Directory Access Protocol (LDAP) (657)  
mail delivery agent (MDA) (672)  
mail relaying (682)  
mail transfer agent (MTA) (672)  
mail user agent (MUA) (672)  
Multipurpose Internet Mail Extensions (MIME) (673)  
open relay (682)  
PHP (663)  
plug-in (665)  
Pretty Good Privacy (PGP) (687)  
Real-time Blackhole List (RBL) (683)  
Secure/Multipurpose Internet Mail Extensions (S/MIME) (685)  
Secure Sockets Layer (SSL) (652)  
Sender Policy Framework (SPF) (683)  
server-side scripting (663)  
Simple Mail Transfer Protocol (SMTP) (671)  
spam (675)  
SSL stripping attack (657)  
Transport Layer Security (TLS) (652)  
Uniform Resource Locator (URL) (650)  
unsolicited commercial e-mail (675)  
X.500 (657)

## Key Terms Quiz

Use terms from the Key Terms list to complete the sentences that follow. Don't use the same term more than once. Not all terms will be used.

1. Spam is the popular term for \_\_\_\_\_.
2. \_\_\_\_\_ is a method for detecting e-mail spoofing.
3. A large source of spam is zombie computers that are part of a(n) \_\_\_\_\_.
4. \_\_\_\_\_ is the protocol used to add attachments to an e-mail.

5. A(n) \_\_\_\_\_ is a compilation of servers that are blocked because they have been known to send spam.
6. \_\_\_\_\_ allows outside users to send e-mail via your mail servers—a risky practice to allow.
7. \_\_\_\_\_ is a protocol for verifying e-mail addresses using DNS records to reduce spam.
8. A(n) \_\_\_\_\_ is a small application program that increases a browser's ability to handle new data types and add new functionality.
9. \_\_\_\_\_ can have the same virus risks as e-mail.
10. The most prevalent protocol that e-mail is sent by is \_\_\_\_\_.

### Multiple-Choice Quiz

1. What is one of the biggest reasons spam is prevalent today?
  - A. Criminals use zombie botnets.
  - B. Regular mail is too slow.
  - C. Spam is popular among recipients.
  - D. Spam is sent from the government.
2. What does the keyword [secure] in a cookie do?
  - A. It causes the system to encrypt its contents.
  - B. It prevents the cookie from passing over HTTP connections.
  - C. It tells the browser that the cookie is a security upgrade.
  - D. None of the above.
3. Why is an open e-mail relay bad?
  - A. It allows anyone to remotely control the server.
  - B. It makes the e-mail server reboot once a day.
  - C. No e-mail will go through.
  - D. It will allow anyone to send spam through the server.
4. Security for JavaScript is established by whom?
  - A. The developer at the time of code development.
  - B. The user at the time of code usage.
  - C. The user through browser preferences.
  - D. Security for JavaScript is not necessary—the Java language is secure by design.

5. What is code signing used to do?
  - A. Allow authors to take artistic credit for their hard work
  - B. Provide a method to demonstrate code integrity
  - C. Guarantee code functionality
  - D. Prevent copyright infringement by code copying
6. Why are instant messaging protocols dangerous for file transfer?
  - A. They bypass server-based virus protections.
  - B. File sharing is never dangerous.
  - C. They allow everyone you chat with to view all your files.
  - D. You'll end up receiving many spam files.
7. Why do PGP and S/MIME need public key cryptography?
  - A. Public keys are necessary to determine whether the e-mail is encrypted.
  - B. The public key is necessary to encrypt the symmetric key.
  - C. The public key unlocks the password to the e-mail.
  - D. The public key is useless and gives a false sense of privacy.
8. Why is HTML e-mail dangerous?
  - A. It can't be read by some e-mail clients.
  - B. It sends the content of your e-mails to web pages.
  - C. It can allow the launching of malicious code from the preview pane.
  - D. It is the only way spam can be sent.
9. If they are both text protocols, why is instant messaging traffic riskier than e-mail?
  - A. More viruses are coded for IM.
  - B. IM has no business purpose.
  - C. IM traffic has to travel outside of the organization to a server.
  - D. Emoticons.
10. TLS provides which of the following functionalities?
  - A. Data integrity services
  - B. Authentication services
  - C. Data confidentiality services
  - D. All of the above

## **Essay Quiz**

1. How would you implement a successful spam-filtering policy?
2. Draft a memo describing malware risks to the common user and what the user can do to avoid infection.

## Lab Projects

### Lab Project 17.1

Show that instant messaging is an insecure protocol. You will need a lab computer with Windows installed, an IM program, and a sniffer. Do the following:

1. If you need to install an IM program, download either Google Chat or Flock from the Internet.
2. Run the Installer program.
3. Generate a username and password and log in.
4. Start the sniffer program and set it to capture all traffic.
5. Start a chat session with a partner in the class.
6. Decode the sniff trace to view the cleartext messages of the chat.

### Lab Project 17.2

Find at least ten pieces of spam mail from any account, whether it be home, work, school, or somewhere else. Using the e-mail headers, and any website that might provide information, attempt to trace the spam mail back to its original source. You will need the following materials:

1. Collect the e-mails and view the e-mail header information in your e-mail program.
2. Find the “Received:” field in the headers and write down as many DNS names or IP addresses as you can. Also look for common details in the header elements of the different messages, such as the same e-mail servers and spammers.
3. Using the Internet, research the physical locations of the IP addresses.
4. Report the different locations from which your spam e-mail originated. What did you learn about tracing e-mail and spam?

Conklin, Wm. Arthur; White, Greg; Cothren, Chuck; Davis, Roger L.; Williams, Dwayne.  
Principles of Computer Security: CompTIA Security+ and Beyond, Sixth Edition (Exam SY0-601) (pp. 690-695). McGraw Hill LLC. Kindle Edition.